

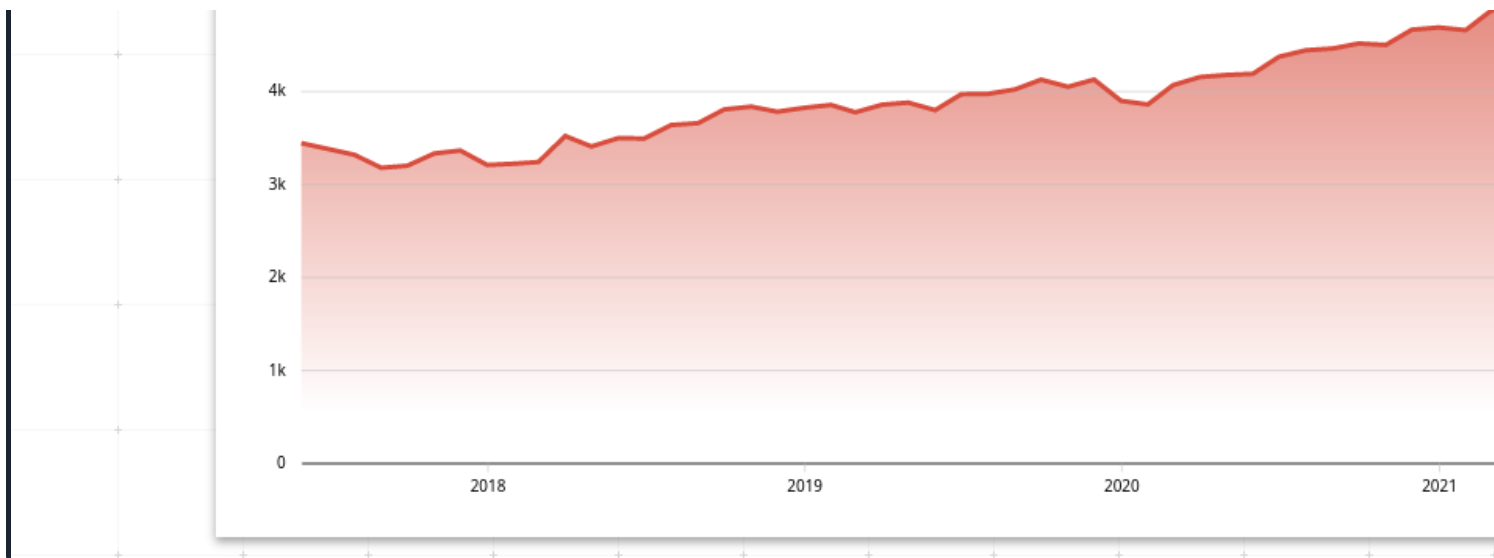
Latest Email Service Vulnerabilities

One of the most recent publicly disclosed and dangerous [Simple Mail Transfer Protocol \(SMTP\)](#) vulnerability [OpenSMTPD](#) up to version 6.6.2 service was in 2020. This vulnerability was assigned [CVE-2020-7247](#) and was exploitable since 2018. This service has been used in many different Linux distributions, such as Debian, Ubuntu, and CentOS. The dangerous thing about this vulnerability is the possibility of executing system commands remotely on the target system. This vulnerability does not require authentication.

According to [Shodan.io](#), at the time of writing (April 2022), there are over 5,000 publicly accessible OpenSMTPD services. The trend is growing. However, this does not mean that this vulnerability affects every service. Instead, we need to be significant the impact of an RCE would be in case this vulnerability were discovered now. However, of course, it would affect many services as well.

Shodan Search

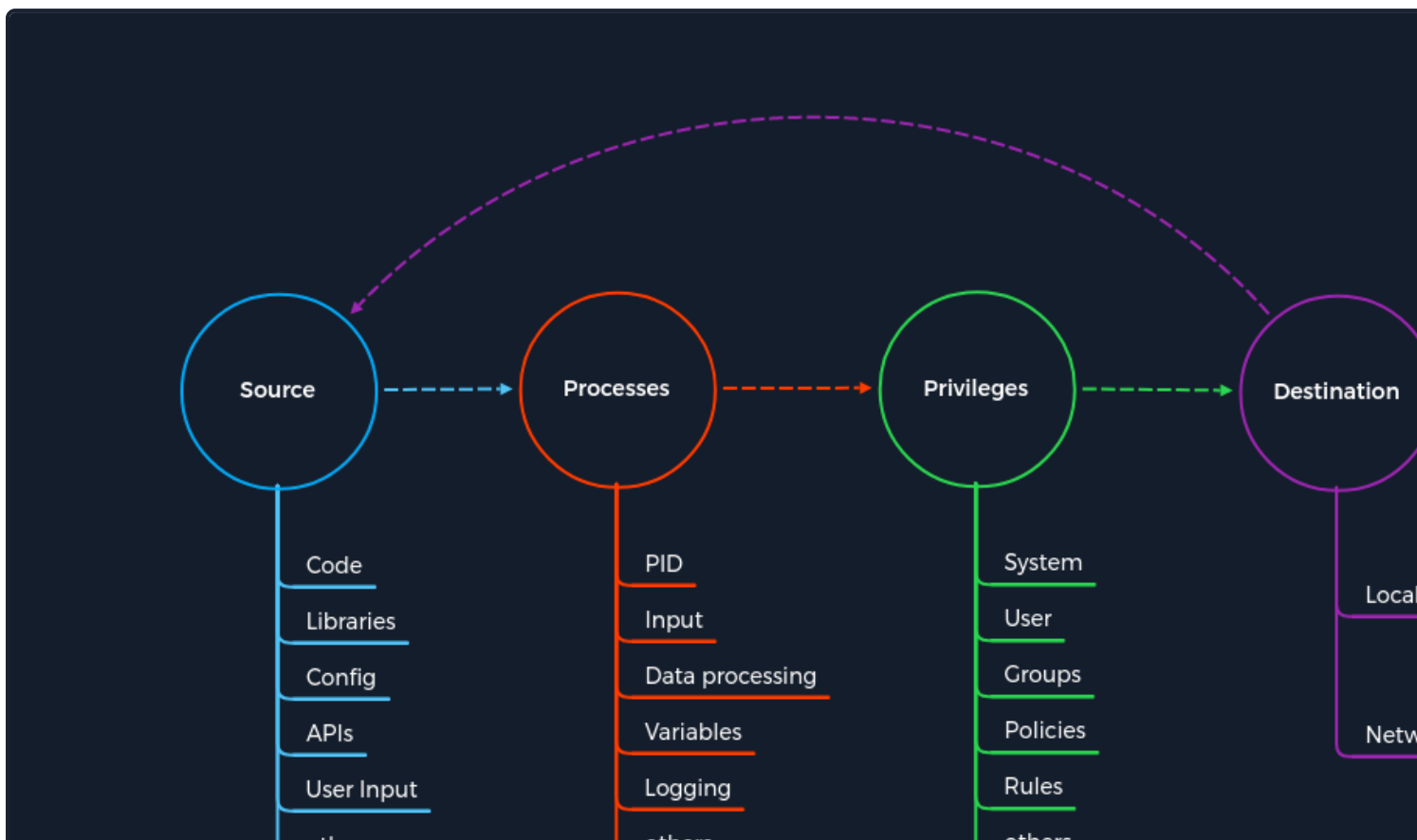
The screenshot shows the Shodan Search interface. At the top, the browser address bar displays the URL: `https://www.shodan.io/search/report?query=port%3A25+product%3A%22OpenSMTPD%22`. Below the address bar is a navigation bar with the Shodan logo and links for "Explore", "Downloads", and "Pricing". The search query `product:"OpenSMTPD"` is entered in the search bar. The main content area features a "Shodan Report" header with the same query. Below the header, there is a section labeled "// GENERAL" and a world map showing the global distribution of OpenSMTPD services. The map is color-coded in shades of red, indicating the presence of the service in various countries across North America, Europe, Asia, and Australia. On the right side of the map, a partial list of countries is visible, including "United", "Germa", "France", "Nethe", and "United".



The Concept of the Attack

As we already know, with the SMTP service, we can compose emails and send them to desired people. The vulnerability lies in the program's code, namely in the function that records the sender's email address. This offers the attacker the ability to execute arbitrary shell commands using a semicolon (;) and making the system execute arbitrary shell commands. However, there can be inserted as a command. The technical details of this vulnerability can be found [here](#).

The Concept of Attacks



5. Listening to the standardized ports of a system requires `root` privileges on the system, and if these ports are used, the service runs accordingly with elevated privileges.
4. As the destination, the entered information is forwarded to another local process.

This is when the cycle starts all over again, but this time to gain remote access to the target system.

Trigger Remote Code Execution

Step	Remote Code Execution
5.	This time, the source is the entire input, especially from the sender area, which contains our system command.
6.	The process reads all the information, and the semicolon (;) interrupts the reading due to special rules in the source code that leads to the execution of the entered system command.
7.	Since the service is already running with elevated privileges, other processes of OpenSMTPD will be executed with the same privileges. With these, the system command we entered will also be executed.
8.	The destination for the system command can be, for example, the network back to our host through which we get access to the system.

An [exploit](#) has been published on the [Exploit-DB](#) platform for this vulnerability which can be used for more functionality of the trigger for the execution of system commands.

Next Steps

As we've seen, email attacks can lead to sensitive data disclosure through direct access to a user's inbox or a misconfiguration with a convincing phishing email. There are other ways to attack email services that can be found in Hack The Box boxes demonstrate email attacks, such as [Rabbit](#), which deals with brute-forcing Outlook Webmail, sending a document with a malicious macro to phish a user, [SneakyMailer](#) which has elements of phishing, accessing an inbox using Netcat and an IMAP client, and [Reel](#) which dealt with brute-forcing SMTP users and phishing.

It's worth playing these boxes, or at least watching the Ippsec video or reading a walkthrough to see examples. This goes for any attack demonstrated in this module (or others). The site [ippsec.rocks](#) can be used to search for and show which HTB boxes these appear in, which will reveal a wealth of targets to practice against.

 [Attacking FTP](#)

[Latest FTP Vulnerabilities](#)

SMB

 [Attacking SMB](#)

[Latest SMB Vulnerabilities](#)

SQL Databases

 [Attacking SQL Databases](#)

[Latest SQL Vulnerabilities](#)

RDP

 [Attacking RDP](#)

[Latest RDP Vulnerabilities](#)

DNS

 [Attacking DNS](#)

[Latest DNS Vulnerabilities](#)

SMTP

 [Attacking Email Services](#)

[Latest Email Service Vulnerabilities](#)

Skills Assessment

 [Attacking Common Services - Easy](#)

 [Attacking Common Services - Medium](#)

 [Attacking Common Services - Hard](#)

My Workstation